سياسة الخصوصية وأمن البيانات

تاريخ السريان: ١ سبتمبر ٢٠٢٦

١. الأدوار والمسؤوليات تجاه البيانات

العيادة المشتركة في منصة ضفيرة هي المتحكم في بيانات مرضاها، وهي المسؤولة عن تحديد أغراض جمعها وأساسه النظامي. وتعمل ضفيرة معالجاً للبيانات نيابة عن العيادة، ولا تستخدمها إلا لتقديم الخدمة وفق تعليمات العيادة وهذه السياسة.

لا تستخدم ضفيرة بيانات المرضى في الإعلانات، ولا تبيعها، ولا تستخدمها في تدريب نماذج الذكاء الاصطناعي.

٢. البيانات التي تعالجها المنصة

- **بيانات المرضى:** البيانات الشخصية، والمواعيد، والسجلات والملاحظات الطبية، والمرفقات، وبيانات التأمين والفواتير.
- **بيانات مستخدمي العيادة:** الاسم، والبريد الإلكتروني، والدور، وسجل الدخول.
- **بيانات تشغيلية:** سجلات النظام وسجل التدقيق، لأغراض الأمان واستمرارية الخدمة.

٣. استضافة البيانات وتشفيرها

تُستضاف البيانات في مركزي بيانات يقعان في منطقتين جغرافيتين منفصلتين: مركز رئيسي، ومركز احتياطي للتعافي من الكوارث.

تُشفَّر جميع البيانات المخزنة بمعيار AES-256، وتُشفَّر جميع الاتصالات بين المتصفح والمنصة باستخدام بروتوكول TLS 1.2 أو أحدث. وتُدار مفاتيح التشفير في خدمة مستقلة، ويُقيَّد الوصول إليها بفريق محدود من مهندسي التشغيل.

٤. النسخ الاحتياطي والتعافي من الكوارث

تُؤخذ نسخة احتياطية مشفرة من بيانات كل عيادة كل ٦ ساعات، وتُحفظ النسخ الاحتياطية مدة ٣٥ يوماً في المركز الاحتياطي.

- **أقصى فقد مقبول للبيانات (RPO):** ٦ ساعات.
- **أقصى مدة لاستعادة الخدمة (RTO):** ٨ ساعات.

تنطبق هذه الالتزامات على جميع الخطط. ويُختبر إجراء الاستعادة من النسخ الاحتياطية مرة كل ٣ أشهر على الأقل.

٥. التحكم في الوصول

يعتمد الوصول إلى البيانات داخل المنصة على دور المستخدم:

الدور	الوصول إلى البيانات
مالك الحساب ومدير العيادة	جميع بيانات العيادة
الطبيب	السجلات والملاحظات الطبية للمرضى، ومواعيده
موظف الاستقبال	البيانات الشخصية للمرضى ومواعيدهم فقط
المحاسب	بيانات الفوترة والتأمين فقط

لا يصل موظفو ضفيرة إلى بيانات العيادة إلا لمعالجة طلب دعم فني، بعد موافقة صريحة من مالك الحساب أو مدير العيادة. ولا يتجاوز الوصول الممنوح ٧ أيام، ويُسجَّل في سجل التدقيق.

٦. أمان الحسابات

- لا يقل طول كلمة المرور عن ١٢ حرفاً.
- يُقفل الحساب مؤقتاً لمدة ١٥ دقيقة بعد ٥ محاولات دخول فاشلة متتالية.
- التحقق الثنائي إلزامي لمالك الحساب ومدير العيادة ابتداءً من ١ أكتوبر ٢٠٢٦، واختياري لبقية الأدوار.
- تنتهي الجلسة تلقائياً بعد ٣٠ دقيقة من عدم النشاط.

٧. سجل التدقيق

تسجل المنصة كل عملية اطلاع على ملف مريض أو تعديله أو حذفه، وكل عملية دخول إلى المنصة، مع هوية المستخدم ووقت العملية.

تُحفظ سجلات التدقيق مدة ١٢ شهراً في الخطتين الأساسية والاحترافية، ومدة ٢٤ شهراً في الخطة المؤسسية. ويمكن تصديرها في الخطتين الاحترافية والمؤسسية.

٨. الاحتفاظ بالبيانات وحذفها

- **ملفات المرضى المحذوفة:** تنتقل إلى سلة المحذوفات وتبقى فيها ٣٠ يوماً قابلة للاستعادة، ثم تُحذف نهائياً.
- **بعد إنهاء الاشتراك:** تبقى بيانات العيادة متاحة للتصدير مدة ٩٠ يوماً من تاريخ إنهاء الاشتراك، ثم تُحذف نهائياً من الأنظمة الرئيسية خلال ٣٠ يوماً بعد ذلك. أما النسخ الاحتياطية فتُحذف تلقائياً عند انقضاء مدة حفظها.
- **التصدير:** يمكن لمالك الحساب تصدير جميع بيانات العيادة في أي وقت بصيغ CSV وPDF، مع المرفقات بصيغها الأصلية.

٩. الجهات المعالجة الفرعية

تستعين ضفيرة بجهات معالجة فرعية محدودة لتقديم الخدمة، منها: مزود البنية السحابية، ومزود خدمة الرسائل النصية. وتخضع هذه الجهات لاتفاقيات تلزمها بمستوى حماية لا يقل عن المستوى الوارد في هذه السياسة. ويُبلَّغ العملاء بأي جهة جديدة قبل ٣٠ يوماً من بدء الاستعانة بها.

١٠. الاستجابة للحوادث الأمنية

عند التأكد من وقوع حادث أمني يمس بيانات عيادة ما، تُبلَّغ العيادة خلال ٧٢ ساعة من التأكد منه. ويتضمن الإبلاغ طبيعة الحادث، والبيانات المتأثرة، والإجراءات المتخذة، والتوصيات الموجهة إلى العيادة.